

EventFlow

Security, Identity & Authorization Design

EF-DOC-007

Version 1.0 - Approved Baseline

Sprint 5

Input baseline: v0.5.0-api

Consolidated SEC-001 through SEC-010

1. Executive Summary

Sprint 5 defines EventFlow's security enforcement architecture before implementation. The design treats Event isolation, guest bearer credentials, privileged Event membership, public/API request boundaries, external providers, imports, PII, audit history and operational resilience as explicit security domains.

Consolidation verdict: DESIGN-COMPLETE / RECONCILIATION PASS. No blocking contradiction was found against the approved Sprint 3 database or Sprint 4 API/application-service baselines. S5-R01 through S5-R16 are mandatory controlled refinements. Two implementation-facing persistence extensions may require versioned migrations: a guest-link credential store (S5-R05) and tamper-evident audit integrity metadata or a companion integrity store (S5-R11).

Metric	Result
SEC controls	10/10 design PASS
Threat register	22/22 covered
Security invariants	10/10 mapped
Security refinements	S5-R01 through S5-R16
Validation scenarios	SV-001 through SV-018 - 18/18 design PASS
Blocking baseline conflicts	None
Status	Draft for Final Review

2. Scope and Security Model

EventFlow uses a zero-assumed-trust request model: input remains untrusted until identity, request integrity, Event scope, authorization, lifecycle, state, concurrency/idempotency and domain rules have all passed. The UI may improve usability but is never the authorization authority.

2.1 Core security properties

- Confidentiality - principals see only authorized Event/resource representations.
- Integrity - unauthorized or conflicting mutations are rejected.
- Availability - critical event-day paths remain usable under reasonable abuse/failure conditions.
- Authenticity - EventFlow distinguishes WordPress users, guests, jobs, providers, migrations and system actions.
- Accountability - material actions remain attributable and auditable.
- Isolation - each Event is a logical security boundary even inside one database.

2.2 Trust boundaries

- TB-01 Public Internet -> WordPress/REST API
- TB-02 Browser/UI -> Server authorization
- TB-03 WordPress identity -> Event Membership/capability policy
- TB-04 Guest credential -> one Event + one Invitation scope
- TB-05 Application services/repositories -> Database
- TB-06 EventFlow -> External communications provider
- TB-07 Provider -> EventFlow webhook ingress
- TB-08 Uploaded file -> Import staging/validation pipeline
- Background-job boundary - committed server job scope replaces user session identity during execution
- Logical Event boundary - Event A resources remain isolated from Event B principals

3. Threat Register - SEC-001

ID	Threat	Impact	Priority	Primary controls / validation
THR-001	Cross-Event resource access / IDOR	Critical	Critical	SEC-003, SEC-005; SV-001, SV-006
THR-002	Event-role privilege escalation	Critical	Critical	SEC-003, SEC-008; SV-002, SV-003, SV-013

THR-003	Invitation-token theft	High	Critical	SEC-004, SEC-006; SV-005, SV-015
THR-004	Invitation/token enumeration	High	High	SEC-004, SEC-009; SV-004
THR-005	Guest scope escape	High	Critical	SEC-003, SEC-004; SV-006
THR-006	CSRF against authenticated browser sessions	High	High	SEC-005; SV-007, SV-008
THR-007	Unauthorized API/request replay	High	High	SEC-004, SEC-005, SEC-006; SV-009, SV-011
THR-008	Forged provider webhook	High	Critical	SEC-006; SV-010
THR-009	Webhook replay	Medium/High	High	SEC-006, SEC-009; SV-011
THR-010	Malicious import/file processing	High	High	SEC-005, SEC-009; SV-012
THR-011	Stored/reflected script injection	High	High	SEC-005; SV-012 + implementation tests
THR-012	SQL/database injection	Critical	Critical	SEC-005; SV-012 + implementation tests
THR-013	Sensitive data exposure in API/secondary stores	High	High	SEC-003, SEC-007; SV-001, SV-013, SV-016
THR-014	Secrets leaked through logs/config/history	Critical	Critical	SEC-006, SEC-008; SV-015
THR-015	Unauthorized membership/ownership change	Critical	Critical	SEC-003, SEC-008; SV-003
THR-016	Duplicate/concurrent business mutation	High	High	SEC-005; SV-009
THR-017	Audit/history tampering	High	High	SEC-008; SV-018
THR-018	Reception account compromise	Medium/High	High	SEC-003, SEC-007, SEC-009; SV-013
THR-019	Resource exhaustion / abuse	Medium/High	Medium/High	SEC-005, SEC-009; SV-004, SV-012, SV-017
THR-020	Compromised/failing third-party provider	High	High	SEC-006, SEC-009; SV-017
THR-021	Vulnerable WordPress/plugin/hosting ecosystem	Critical	High	SEC-001, SEC-006, SEC-008, SEC-009; blast-radius controls
THR-022	Unauthorized archived-Event mutation	High	High	SEC-003, SEC-005; SV-014

4. Security Invariants - SEC-001

Invariant	Requirement
INV-SEC-01	Every Event-scoped resource operation verifies Event ownership/scope server-side.
INV-SEC-02	Authentication never substitutes for authorization.
INV-SEC-03	Client/UI state is never an authorization authority.
INV-SEC-04	Guest access is limited to the Event and Invitation represented by validated credential/session scope.
INV-SEC-05	Raw Invitation tokens and reusable application/provider secrets never appear in ordinary persistent storage or logs.
INV-SEC-06	Provider callbacks are untrusted until authentication and replay/deduplication controls pass.
INV-SEC-07	Uploaded files remain untrusted throughout parsing and staging.
INV-SEC-08	Sensitive state-changing operations use server authorization plus replay/concurrency controls appropriate to the operation.
INV-SEC-09	Archived state cannot be bypassed by otherwise-valid role or credential.
INV-SEC-10	Security-relevant administrative actions remain attributable.

5. Principal & Authentication Model - SEC-002

EventFlow normalizes authenticated actors into a server-side PrincipalContext. Administrative identities remain WordPress identities; EventFlow does not create a parallel password system. Authorization is evaluated separately after authentication.

Principal	Authentication source	Security scope
-----------	-----------------------	----------------

WordPress user	WordPress session + REST request protection	Identity only; Event membership/capabilities checked separately
Global EventFlow admin	WordPress user + dedicated global capability	Platform recovery/security/system functions
Invitation guest	High-entropy Invitation credential -> server-verifiable guest session	One Event + one Invitation + current token version
Background job	Server-created committed job	Defined Event/job/operation scope
Provider webhook	Provider-specific signature/secret verification	Provider event processing only
Migration	Controlled migration runner	Defined migration operation
System	Internal named system operation	Explicit system capability only

5.1 Authentication requirements

- Guest sessions are short-lived relative to Invitation credentials and are invalidated by Invitation rotation/revocation/current-state changes.
- Provider verification occurs before payload normalization/business processing.
- Background job authority derives from committed server-side job type and scope, not serialized client role claims.
- High-risk security changes may require recent/step-up authentication where the WordPress environment supports it.
- Raw credentials, cookies, nonces, provider secrets and authorization headers are never logged.

6. Authorization & Capability Model - SEC-003

Roles are predefined capability bundles; authorization code evaluates explicit capabilities/policies rather than scattering direct role-name comparisons. Event scope, lifecycle and resource/domain state remain overlays. Authorization is default-deny.

Capability area	Primary Owner	Owner	Organizer	Coordinator	Reception	Reporting
View Event	Yes	Yes	Yes	Yes	Limited	Yes
Edit Event	Yes	Yes	Yes	Limited	No	No
Activate/Complete	Yes	Yes	Policy	No	No	No
Archive/Restore	Yes	Policy	No	No	No	No
Manage staff memberships	Yes	Yes	Policy	No	No	No
Manage owners	Yes	No	No	No	No	No
Transfer primary owner	Yes	No	No	No	No	No
Manage Invitations	Yes	Yes	Yes	Yes	No	No
Rotate/Revoke token	Yes	Yes	Yes	Policy	No	No
Manage Attendees	Yes	Yes	Yes	Yes	No	No
Manage Seating	Yes	Yes	Yes	Yes	No	No
Override required group	Yes	Yes	Yes	Policy	No	No
Check-in	Yes	Yes	Yes	Yes	Yes	No
Reverse check-in	Yes	Yes	Yes	Policy	No	No
Manage Templates	Yes	Yes	Yes	Policy	No	No
Queue Campaign	Yes	Yes	Yes	Policy	No	No
Manage Imports	Yes	Yes	Yes	Policy	No	No
View Audit	Yes	Yes	Yes	Limited	No	Limited
View Reports	Yes	Yes	Yes	Yes	Limited	Yes
Export PII	Yes	Yes	Policy	No	No	Policy

6.1 Privilege rules

- Only current primary owner or authorized global recovery administrator transfers primary ownership.
- Ordinary owner/organizer authority does not imply provider-secret or system-security access.
- Reception is intentionally narrow: search, limited seating context and check-in; no broad PII, campaigns, seating mutation or membership management.
- Reporting is read-only and aggregate-first; PII export requires stronger explicit capability.
- Unknown roles, capabilities, principals, jobs and lifecycle transitions fail closed.

7. Guest Token & Session Security - SEC-004

- Invitation credentials use cryptographically secure high-entropy opaque tokens (≥ 128 effective bits; 192-256 preferred).
- Raw Invitation tokens are never persisted; deterministic cryptographic digests are stored for lookup.
- Credential-bearing URLs are consumed quickly into short-lived Secure/HttpOnly/SameSite guest sessions and redirected to clean URLs.
- Bootstrap pages/responses use restrictive referrer/cache/logging policies and avoid unnecessary third-party resources.
- Session authorization rechecks Invitation/Event state and token version; rotation or revocation invalidates existing guest sessions.
- SameSite is defense-in-depth; guest mutations also require explicit CSRF/origin protection.
- Opening an Invitation link never performs irreversible business mutation, protecting against email link scanners.

8. API & Request Security - SEC-005

The request security pipeline is: HTTPS -> infrastructure limits -> route/method/content-type -> authentication -> CSRF/origin -> abuse controls -> schema validation -> authorization/Event scope -> concurrency/idempotency -> application service/domain validation -> persistence -> safe response.

- Production is HTTPS-only; sensitive cookies are Secure.
- GET never performs irreversible state changes.
- Administrative and guest browser APIs are same-origin by default; credentialed wildcard CORS is prohibited.
- State-changing WordPress browser requests require supported REST nonce/request protection; guest cookie mutations require guest CSRF protection.
- Request bodies, strings, arrays, collections, searches, pagination and uploads are bounded.
- Unknown/mass-assignment fields are rejected for sensitive commands; identifiers are authoritative only after server-side Event ownership resolution.
- Repositories use parameterized SQL; sort/filter fields are allowlisted; user content is contextually escaped and rich HTML allowlist-sanitized.
- Security-sensitive URLs use canonical trusted configuration, not unvalidated Host headers.
- PII-bearing exports and uploads receive dedicated controls; CSV formula injection is explicitly neutralized.

9. Secrets & Provider Security - SEC-006

Reusable provider, signing, encryption and runtime secrets are credential material, not business data. Business tables store credential references/non-secret metadata; SecretProvider implementations resolve values from runtime configuration or dedicated secret stores.

9.1 Provider adapter controls

- Provider credentials are least-privilege and environment-specific.
- Provider adapters declare idempotent-send, status-lookup, webhook-signature, timestamp and retry capabilities.
- Webhook authentication precedes normalization and domain processing; replay/dedupe is layered with authentication.
- Rotation can use bounded current/previous overlap where operationally necessary.
- Credential changes are global-security operations, not Event-owner rights, and are audited without secret values.

9.2 Guest-link indirection reconciliation

Sprint 4 Message history remains immutable, but it must not permanently retain the underlying reusable Invitation token. Outbound invitation Messages therefore use a purpose-scoped opaque guest-link credential, preferably issued

per logical Message recipient. The link credential is high entropy, stored only as a digest, resolved server-side to the Invitation, and never outlives current Invitation/Event authorization.

Implementation impact: a small supporting guest-link credential store/table is likely required. This is a controlled security extension implemented through a versioned migration; it does not invalidate the Sprint 3 core PDM.

10. Data Protection & Privacy - SEC-007

Data class	Examples	Baseline handling
Public / low sensitivity	Public Event name/date/venue	Guest/public where intentionally exposed
Operational	Table number, invitation/campaign status	Event-scoped authorization
PII / sensitive	Name, email, phone, dietary/accessibility, RSVP, check-in	Purpose-minimized and role/representation restricted
Critical credential/security	Tokens, sessions, provider keys, DB credentials	Dedicated credential controls; never ordinary business data

- Reception and reporting use privacy-minimized DTOs; field-level restrictions apply to especially sensitive data.
- Import source files/raw staging have shorter retention than authoritative Event records.
- Audit and logs minimize PII and do not duplicate confidential notes unnecessarily.
- PII exports are protected temporary artifacts with authorization, expiry, no-store semantics and audit trail.
- Archive is not purge; permanent deletion/anonymization is a separate governed process.
- Backup restore must account for privacy-state reconciliation; production guest data should not casually be copied to development/staging.
- Plugin uninstall and WordPress-user deletion do not implicitly purge EventFlow business/history data.

11. Audit & Security Logging - SEC-008

Business/security audit and operational logs are separate channels. Audit answers who did what/where/when and preserves material accountability. Operational logs capture technical execution and diagnostics with shorter retention and stronger minimization.

- AuditService is the sole application writer for append-only audit records; ordinary APIs cannot create/edit/delete audit history.
- Audit attribution preserves actual principal type plus initiating user/job/provider context as applicable.
- Material mutations normally commit required audit records in the same transaction; required audit failure rolls back the mutation.
- Audit before/after data is field-minimized and centrally redacted for secrets/sensitive PII.
- Structured logs prefer internal IDs over names/emails and protect against log injection.
- Security-critical audit history should support tamper-evident chain verification; verification failure is high/critical and is not auto-repaired.

Implementation impact: S5-R11 may be implemented using hash/previous-hash columns on audit records or a companion integrity store. If persisted schema changes are used, they must be introduced by versioned migration.

12. Abuse & Operational Controls - SEC-009

- Rate limiting is risk-based per surface: bootstrap strict; RSVP moderate; reception/check-in higher burst tolerance; imports/exports low-frequency; webhooks provider-tuned.
- Enumeration, cross-Event probing, repeated privilege denials, suspicious PII exports, webhook failures and abnormal event-day activity produce security signals.
- Containment favors temporary/narrow controls (rate tightening, session revocation, membership suspension, provider/job pause) over global shutdown.

- XLSX/import parsers limit uploaded and expanded content, worksheet/row/cell/string complexity.
- External providers use bounded retry, Retry-After where available and circuit breakers to prevent retry storms.
- Queue/job concurrency and retry caps prevent unbounded background work.
- Event-day reception lookup/check-in receive operational priority over imports, exports, recommendation jobs and large communications workloads.
- Failure of optional external subsystems should preserve unrelated EventFlow domains where integrity can still be maintained.

13. Security Validation Matrix - SEC-010

ID	Scenario	Threats	Attack/failure	Expected outcome	Design
SV-001	Cross-Event IDOR	THR-001, THR-013	Organizer of Event A targets Event B resource	404 resource_not_found; no disclosure/mutation; probing telemetry	PASS
SV-002	Role privilege escalation	THR-002, THR-015	Coordinator attempts owner grant/self-elevation	403/default deny; repeated attempts signaled	PASS
SV-003	Unauthorized primary-owner transfer	THR-002, THR-015	Organizer/ordinary owner attempts transfer	403; only current primary owner/global recovery authority; audit legitimate transfer	PASS
SV-004	Invitation-token enumeration	THR-003, THR-004, THR-019	Automated random credential probing	Generic failure, throttling, enumeration signal; no validity oracle	PASS
SV-005	Old token after rotation	THR-003, THR-007	Use v4 token/session after v5 rotation	401 invitation_access_inv alid; prior sessions invalid	PASS
SV-006	Guest scope escape	THR-001, THR-005, THR-013	Guest for one Invitation targets other resources	Deny; server-bound Event+Invitation scope	PASS
SV-007	Guest CSRF	THR-006	Cross-site RSVP mutation with valid guest cookie but no CSRF/origin evidence	Deny; telemetry; no mutation	PASS
SV-008	Administrative CSRF	THR-006	External site targets logged-in WordPress user	Deny without required REST nonce/request protection	PASS
SV-009	RSVP duplicate/replay	THR-007, THR-016	Replay same key/request, then same key/different body	Replay prior outcome; conflict on fingerprint mismatch; scoped idempotency	PASS
SV-010	Forged provider webhook	THR-008	Valid-looking JSON with invalid/missing provider signature	Deny before domain processing; security telemetry	PASS
SV-011	Valid webhook replay	THR-007, THR-009	Replay authentic provider callback	Dedupe; no duplicate transition; cheap acknowledgement	PASS
SV-012	Malicious import	THR-010, THR-011, THR-012, THR-019	Malformed/oversized/formula/script/archive-bomb payloads	Bounded parser/staging; no code/SQL execution; no direct production insert	PASS
SV-013	Reception account compromise	THR-002, THR-013, THR-018	Compromised Reception principal attempts broader access	Only reception search/check-in/limited seating read; broader actions denied	PASS
SV-014	Archived Event mutation	THR-022	Valid owner attempts mutation on archived Event	Deny event_archived despite role capability	PASS

SV-015	Secret leakage inspection	THR-014	Inspect logs/audit/errors/message history after credential operations	No reusable secrets; guest-link indirection used	PASS
SV-016	PII export abuse	THR-013, THR-018	Unauthorized broad export; repeated authorized exports	403 without export_pii; authorized artifact protected/expiring/audited; anomaly signal	PASS
SV-017	Provider outage/retry storm	THR-019, THR-020	Timeout/429/5xx repeatedly	Bounded backoff, Retry-After, circuit breaker; unrelated domains remain available	PASS
SV-018	Audit integrity failure	THR-017	Modify/delete/reorder test audit record then verify chain	Integrity failure and high/critical signal; no silent repair	PASS

13.1 Validation coverage

SEC-010 maps all 10 security invariants and all 22 threats to explicit controls and adversarial validation scenarios. The scenarios are design-level PASS contracts, not evidence that unimplemented code has already passed penetration or integration testing. Before any production-ready declaration, the implemented system must execute SV-001 through SV-018 plus lower-level injection, CORS, redirect, request-boundary, parser, default-deny and domain-wide Event-isolation tests.

14. Sprint 5 Refinement Register

ID	Mandatory requirement
S5-R01	Message history must not permanently store the underlying long-lived Invitation token; outbound links use secure indirection.
S5-R02	Idempotency records are scoped by authoritative principal/operation/Event and canonical request fingerprint.
S5-R03	Spreadsheet-compatible import/export explicitly protects against formula injection.
S5-R04	Security-sensitive absolute URLs are generated from trusted canonical application configuration, not untrusted Host headers.
S5-R05	Outbound invitation communications use purpose-scoped high-entropy guest-link credentials, preferably per logical Message recipient, stored only as digests.
S5-R06	Reusable provider, signing, encryption and runtime secrets are externalized behind a SecretProvider abstraction.
S5-R07	Import source files and raw staging payloads receive explicit short-lived retention.
S5-R08	PII exports are temporary protected artifacts with authorization-controlled retrieval and expiry.
S5-R09	Backup/restore procedures account for privacy-state reconciliation after restoration.
S5-R10	Plugin uninstall and WordPress-user deletion do not implicitly purge EventFlow history.
S5-R11	Security-critical audit history should support tamper-evident chained integrity verification.
S5-R12	Operational logging uses structured encoding or equivalent log-injection protection.
S5-R13	If a material mutation requires an audit record, inability to persist that audit fails/rolls back the mutation.
S5-R14	Import parsers enforce upload and expanded/parsing complexity limits, including XLSX archive expansion.
S5-R15	External provider integrations support bounded backoff and circuit-breaker behavior.
S5-R16	Event-day critical paths receive operational priority over non-critical heavy workloads.

15. Sprint 3 / Sprint 4 Baseline Reconciliation

Area	Existing baseline	Sprint 5 requirement	Result	Implementation note
Guest credential storage	Sprint 3 Invitation token digest + Sprint 4 return-once token	SEC-004/006	Compatible	No core redesign. Adds guest-link indirection for outbound Messages.
Message immutability	Sprint 4 immutable rendered Message snapshot	S5-R01/R05	Compatible with refinement	Message retains indirection URL, not underlying Invitation token.
Guest-link persistence	No dedicated Sprint 3 entity	S5-R05	Controlled extension required	Likely supporting table/store for per-Message opaque link digest, expiry/revocation/context. Implement via versioned migration.
Idempotency	Sprint 4 generic Idempotency-Key semantics	S5-R02	Compatible	Implementation idempotency store must scope principal/operation/Event + request fingerprint.
Audit	Sprint 3 audit model; Sprint 4 AuditService	S5-R11/R13	Compatible with possible extension	Tamper-evident chain may require hash/previous-hash metadata or companion integrity store; versioned migration if persisted.
Imports	Sprint 3 staging + Sprint 4 staged/batched apply	S5-R07/R14	Compatible	Adds retention/complexity controls; no domain change.
Exports	Sprint 4 report/export concepts	S5-R03/R08	Compatible	Protected expiring artifact semantics are implementation/ops concern.
Provider adapters	Sprint 4 provider capability-aware retries	S5-R06/R15	Compatible	Externalized secrets + circuit breaker deepen existing adapter contract.
Reception	Sprint 4 least-privilege DTO/check-in	SEC-003/007/009	Compatible	Security formalizes capability and abuse limits.
Event lifecycle	Sprint 4 completed/archived overlays	SEC-003/005	Compatible	Archived mutation remains server-side denied; late historical evidence still permitted.
Backup/restore	Future migration/recovery plan reserved	S5-R09	Deferred dependency	Must be carried into future migration/recovery documentation; no Sprint 3/4 contradiction.
Plugin/user deletion	Not a normal API purge operation	S5-R10	Compatible	Implementation uninstall hooks must preserve data unless explicit governed destructive action.

15.1 Reconciliation verdict

PASS. Security decisions strengthen rather than contradict the approved domain and API baselines. S5-R05 and S5-R11 are the only refinements likely to require new persistent supporting structures. They must be introduced as controlled schema migrations; the Sprint 3 v1.0 baseline remains an immutable historical checkpoint. S5-R09 is intentionally carried forward into the future migration/upgrade/recovery documentation.

16. Security Acceptance Gate

Gate	Required result
Authentication tests	PASS
Authorization tests	PASS
Cross-Event isolation	PASS
Guest credential/session tests	PASS
CSRF/request security	PASS

Replay/idempotency	PASS
Webhook authentication/replay	PASS
Import parser security	PASS
PII/export protection	PASS
Secret leakage inspection	PASS
Audit integrity verification	PASS
Abuse/resilience	PASS
SV-001 through SV-018	ALL PASS

No production-ready security declaration may be made while a Critical security scenario is failing.

17. Open / Future Operational Dependencies

- Detailed TLS/web-server/WordPress/OS/database hardening belongs in deployment operations documentation.
- Migration, rollback, backup/restore and privacy-state reconciliation belong in the future Migration/Upgrade/Recovery Plan.
- Incident response playbooks should cover compromised owner account, Invitation credential leak, provider secret leak, PII export anomaly, audit-integrity failure and database/server compromise.
- Exact retention durations and rate-limit thresholds remain deployment/governance configuration with safe defaults.
- Formal legal/privacy compliance requirements must be established by the deploying organization/jurisdiction rather than inferred by EventFlow engineering.

18. Consolidation Status

Sprint 5 completeness and consistency review: PASS. SEC-001 through SEC-010 are consolidated. Threat coverage is 22/22, security invariants 10/10, and validation scenarios SV-001 through SV-018 are design PASS. S5-R01 through S5-R16 are reconciled as mandatory controlled refinements. No blocking architectural contradiction remains. This document is v1.0 Approved Baseline following explicit final approval and document QA.